

Grafos de Conhecimento Centrados na Sessão HTTP para Detecção Explicável e Mitigação de Escopo Derivado de DDoS de Camada de Aplicação

Natanael Oliveira, Arthur Kobielski, Marcos Luna, Luigi Carro, Jéferson Campos Nobre e Eder John Scheid
Instituto de Informática, Universidade Federal do Rio Grande do Sul (UFRGS), Porto Alegre, Brasil
{natanael.oliveira, arthur.kobielski, marcos.luna, carro, jcnobre, ejscheid}@inf.ufrgs.br

Resumo—Campanhas distribuídas de Slow HTTP DoS mantêm cada origem abaixo de qualquer limiar por sessão, de modo que o sinal de ataque mora na estrutura *entre* sessões. Os detectores descartam essa estrutura ao reduzir sessões a vetores, e os detectores recentes baseados em grafos de conhecimento raciocinam sobre nós de rede e param em um relatório de texto. Modelamos a sessão HTTP como entidade de primeira classe em OWL, ligada a outras sessões por seis sub-propriedades tipadas, ponderadas pelo custo que o atacante teria para quebrar cada sinal. Uma regra SPARQL/SWRL dispara sobre a massa ponderada dessas ligações, e sua derivação é o veredicto, exportado como cadeia de evidência em JSON-LD e STIX 2.1 cujo discriminador define o escopo da mitigação. Contra campanhas furtivas de *botnets* de dispositivos comprometidos, a detecção por sessão fica no acaso em quatro famílias de classificador, enquanto a representação entre sessões alcança ROC AUC 0,98. Em *datasets* públicos, cujos ataques carregam assinaturas de fluxo evidentes, uma linha de base forte por sessão basta. Definir o escopo da mitigação pela propriedade que a maior parte do agrupamento compartilha seleciona uma impressão digital *legítima* quando a *botnet* se espalha por várias pilhas TLS, bloqueando 0% do ataque e 39% do tráfego legítimo. Definir o escopo por enriquecimento bloqueia de 85 a 90% sem colateral observado. Como detector, o caminho simbólico dispensa treino e ainda recupera de duas a cinco vezes mais de uma campanha fragmentada do que um modelo aprendido com zero falsos positivos.

Index Terms—gestão de segurança, grafo de conhecimento, DDoS de camada de aplicação, modelos semânticos, raciocínio automatizado, explicabilidade, política de mitigação

I. INTRODUÇÃO

Os ataques de negação de serviço distribuída (DDoS) de camada de aplicação continuam crescendo em volume e frequência. Em agosto de 2023, o HTTP/2 Rapid Reset (CVE-2023-44487) levou os picos mitigados a 398 milhões de requisições por segundo, a partir de uma *botnet* de cerca de vinte mil máquinas [1], [2], e a Cloudflare bloqueou mais de 6 500 ataques hiper-volumétricos só no segundo trimestre de 2025, com o DDoS sobre HTTP crescendo 129% ano a ano [3]. Ataques dessa magnitude são, porém, justamente o que as defesas volumétricas foram construídas para absorver, e a detecção fica mais difícil na ponta de baixa taxa do espectro. É ali que está a família de ataques *distribuídos de Slow*

HTTP DoS: o Slowloris e seus descendentes, mais variantes baseadas em taxa que ainda sustentam conexões abertas, como HULK e GoldenEye [4]. Eles exaurem um servidor a partir de várias origens coordenadas, cada uma enviando requisições pequenas o bastante para que nenhum limiar por origem seja ultrapassado, e é isso que os torna difíceis de identificar.

Uma campanha furtiva também molda cada sessão para parecer legítima nos sinais por sessão em que os detectores se apoiam, como duração da conexão e entropia de rotas [5]. O que continua discriminativo vive na estrutura *entre* sessões: a mesma impressão digital de cliente se repetindo em muitas origens, e essas origens convergindo sobre um mesmo *endpoint*. Posto nesses termos, o problema pertence à gestão de redes e serviços tanto quanto à detecção, porque agir sobre ele exige uma decisão: *quais* clientes tratar, com base em *qual* evidência, e com um filtro estreito o bastante para poupar os usuários legítimos do serviço atacado.

O trabalho existente ataca o lado da detecção desse problema e deixa o operacional em aberto. Uma meta-análise de 75 estudos constata que 47% dos detectores de DDoS de camada de aplicação derivam seus atributos de sessões HTTP [6], e essas sessões são achatadas em um vetor numérico antes de chegar ao classificador. O detector passa então a enxergar estatísticas sobre sessões, e não consegue raciocinar sobre impressões digitais que se repetem entre origens nem sobre padrões que só existem entre sessões individualmente normais. Detectores baseados em grafos preservam essas relações: o KLAGÉ [7] constrói grafos de conhecimento a partir de *logs* de rede, classifica nós com Graph-BERT [8] e reporta em linguagem natural, alcançando $F_1 = 84,1\%$ em *benchmarks* de IoT com DDoS Slowloris. Três oportunidades permanecem abertas. Primeiro, a unidade de raciocínio é o *nó de rede* (porta, IP, fluxo), enquanto a coordenação de camada 7 só se torna visível no nível da sessão de aplicação. Segundo, a coordenação é capturada implicitamente, em *embeddings* aprendidos, de modo que nenhum operador consegue inspecionar as relações por trás do veredicto. Terceiro, a saída para no relato, enquanto agir sobre ele exige uma política de mitigação cujo escopo decorra do grafo. Essas três lacunas definem o espaço que este artigo ocupa.

Tabela I
COMPARAÇÃO DOS TRABALHOS RELACIONADOS

Trabalho	Ano	Objetivo	Unidade de Raciocínio	Relação entre Sessões	Explicação do Veredicto	Escopo de Mitigação
[9]	2012	DDoS L7	Sessão como Vetor	-	-	-
[10]	2015	Anomalias de Fluxo	Estatística de Fluxo	-	-	-
[5]	2023	DoS L7	Sessão como Vetor	-	-	-
[11]	2024	Dependências entre Dispositivos	Dispositivo de Rede	Implícita (Aprendida)	-	-
[12]	2024	Intrusão em TI	Host	Implícita (Aprendida)	-	-
[13]	2024	Tráfego de Bots	Impressão Digital JA4	Proprietária	-	Não divulgado
[7]	2026	Ameaças de Rede	Nó de Rede	Implícita (Aprendida)	A posteriori (LIME/LLM)	-
Este Trabalho	2026	DDoS L7 Distribuído	Sessão de Aplicação	Explícita (Tipada e Ponderada)	Derivação	Derivado

Este artigo as endereça com uma solução baseada em grafos de conhecimento para detectar e mitigar DDoS de camada de aplicação. Ela captura tráfego HTTP/TLS ao vivo, extrai de cada requisição informação de impressão digital, fluxo e *end-point*, e associa a requisição a um nó `ApplicationSession` de um grafo OWL mantido ao longo de uma janela deslizante. As sessões dessa janela são ligadas por seis sub-propriedades tipadas, ponderadas pelo custo que o atacante teria para quebrar cada sinal, e uma regra SPARQL/SWRL dispara sobre a massa ponderada dessas ligações. O operador recebe, portanto, a derivação que satisfaz a regra, e o discriminador que ela nomeia passa a ser o escopo da mitigação. O alvo são campanhas conduzidas por *botnets* de dispositivos comprometidos, cujas pilhas TLS seu operador não consegue trocar a baixo custo, e bots que apresentam a impressão digital de um navegador são avaliados como a fronteira do método. Este artigo traz quatro contribuições. (i) Propomos uma ontologia OWL na qual a sessão HTTP é entidade de primeira classe, relacionada a outras sessões por *seis sub-propriedades tipadas* ponderadas pelo custo de evasão, de modo que a proximidade de rede, que *botnets* modernas quebram trivialmente, entra apenas como evidência auxiliar. (ii) Definimos um procedimento de decisão em que uma regra SPARQL/SWRL dispara sobre a massa de coordenação ponderada $\Omega(S)$ de um agrupamento candidato, de modo que o veredicto reportado é a derivação que satisfaz a regra. (iii) Derivamos o escopo de mitigação do mesmo grafo e o exportamos com sua cadeia de evidência em JSON-LD e STIX 2.1. Mostramos que a escolha natural, a propriedade que a maior parte do agrupamento compartilha, é prejudicial em condições realistas, e a substituímos por um critério de enriquecimento sobre um perfil de tráfego normal. (iv) Avaliamos a abordagem contra uma linha de base forte por sessão à medida que a campanha se torna mais distribuída, e medimos a taxa de falsos positivos do filtro de mitigação resultante como dano colateral sobre o tráfego legítimo.

A Seção II revisa os trabalhos relacionados, a Seção III apresenta o *framework* e a Seção IV, a metodologia de avaliação. A Seção V reporta os resultados, a Seção VI discute o posicionamento operacional e as limitações, e a Seção VII conclui.

II. TRABALHOS RELACIONADOS

A Tabela I compara este trabalho com o estado da arte em quatro dimensões: a unidade de raciocínio, a representação das relações entre sessões, a forma da explicação e se um escopo

de mitigação e seu custo colateral decorrem dessa representação. As subseções tratam dos grafos de conhecimento de segurança, da detecção de camada 7 e de como ambos tratam as sessões.

A. Grafos de Conhecimento em Segurança e Gestão

A primeira onda de grafos de conhecimento em segurança foi *estática*: entidades extraídas de Common Vulnerabilities and Exposures (CVE), relatórios e *blogs*, normalizadas e ligadas em uma base consultável [14], [15]. Uma revisão da área enuncia a lacuna resultante [16]: “*it is still unclear how to implement the knowledge graph to face real industrial difficulties in cyber attack and defense situations*”. Grafos construídos a partir de texto de inteligência de ameaças não capturam a estrutura do tráfego em tempo de execução.

Trabalhos mais recentes populam grafos a partir do próprio tráfego, e o KLAGE [7] é o mais próximo destes da abordagem aqui proposta. Representações em grafo também vêm ganhando espaço em tarefas adjacentes de gestão: uma linha identifica dependências entre dispositivos por predição de ligações sobre grafos de rede [11], outra aprende sequências de ações de ataque a partir de medições em bancada [12]. Ambas operam sobre entidades de nível de rede, e nenhuma deriva um escopo de mitigação do que encontra.

B. Detecção de DDoS de Camada 7 sobre HTTP

O estado da arte em detecção de DDoS de camada 7 sobre HTTP [4], [17] divide-se em duas categorias: (i) perfilamento estatístico e (ii) aprendizado de máquina. A primeira aplica Análise de Componentes Principais (PCA) a estatísticas de fluxo [10] ou a uma matriz comportamental por sessão [9], sendo esta última uma das primeiras formulações a pôr a sessão no centro, ainda que como vetor de atributos. A segunda categoria, mais recente, aplica aprendizado supervisionado sobre atributos de sessão [5], cujos autores observam que o método não foi validado em tempo real e que sua saída é binária, sem explicação ontológica. Nenhuma das duas categorias preserva uma relação entre sessões: a coordenação existente é dissolvida no vetor de atributos antes que o classificador chegue a vê-la.

C. Modelagem de Sessão em Detecção de Anomalias

Entre os 75 estudos de uma meta-análise sobre o tema [6], nenhum mantém a sessão como objeto com identidade, alvo,

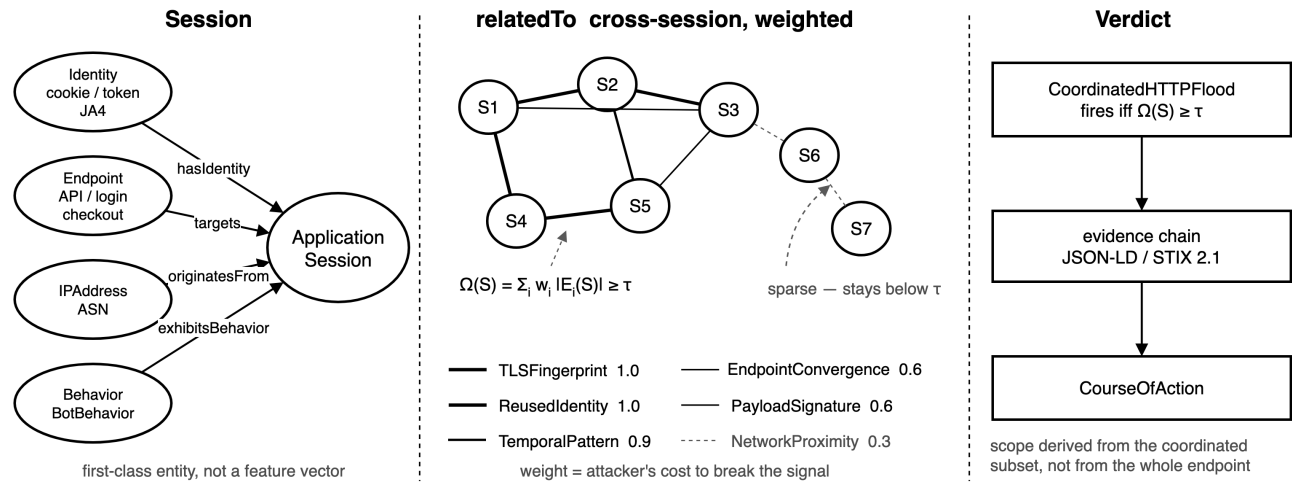


Fig. 1. Ontologia centrada na sessão e regra de detecção.

comportamento e relações tipadas. A redução é uniforme, e coloca o raciocínio entre sessões fora do alcance do detector.

Plataformas industriais de gestão de *bots* de fato exploram estrutura entre sessões: sinais agregados por impressão digital JA4 sobre todo o tráfego recente alimentam a pontuação de *bots* e a proteção contra DDoS [13]. São proprietárias, porém, sem ontologia pública, sem *benchmark* acadêmico reproduzível e sem métrica formalizada de dano colateral.

A Tabela I torna a fronteira explícita. Detectores estatísticos e de aprendizado de máquina reduzem a sessão a um vetor, de modo que nenhuma relação entre sessões sobrevive, e nenhum escopo de mitigação ou custo pode decorrer da decisão. Detectores baseados em grafos preservam relações, mas sobre entidades de nível de rede e em forma aprendida, o que produz uma classificação e, na melhor das hipóteses, uma explicação reconstruída a posteriori. Plataformas industriais agem sobre agregados por impressão digital e não divulgam nem a representação nem o custo de agir sobre ela. Nenhuma abordagem publicada, portanto, reúne três propriedades: a sessão de aplicação como unidade de raciocínio, relações entre sessões explícitas e tipadas, e um escopo de mitigação derivado da representação que produziu o veredicto, com seu dano colateral reportado. O restante deste artigo fornece essa combinação e mede quanto ela custa quando o escopo erra.

III. GRAFO DE CONHECIMENTO CENTRADO NA SESSÃO

A Fig. 1 resume o *framework*. Quatro estágios correm sobre tráfego ao vivo: eventos HTTP são ingeridos, elevados a instâncias da ontologia, com as sessões como nós persistentes do grafo, avaliados por regras semânticas e convertidos em um veredicto que carrega sua cadeia de evidência e o escopo de mitigação derivado.

A. Empregando Grafos de Conhecimento

Um grafo de conhecimento enuncia fatos como triplas RDF (sujeito, predicado, objeto), e uma ontologia OWL 2 declara as classes e propriedades que essas triplas podem usar. Trabalhamos no perfil OWL 2 RL [18], cujo encadeamento

progressivo polinomial torna a materialização limitada tratável para raciocínio em tempo de execução, onde OWL 2 DL não é. A materialização roda uma vez por janela operacional, fora do caminho por requisição. O SWRL acrescenta regras de Horn, que afirmam uma tripla quando uma conjunção de premissas se verifica. O SPARQL consulta o resultado e agrega sobre conjuntos de soluções, o que o SWRL não faz. A identidade do cliente vem do JA4 [19], um *hash* do *ClientHello* TLS que identifica a pilha TLS do cliente. Por ser independente do endereço de origem, ele sobrevive à rotação de IP.

B. Definindo a Ontologia

A classe central é *ApplicationSession*, relacionada por *hasIdentity* a uma *Identity* composta (*cookie*, *token* JWT, nome de usuário, impressão digital TLS), por *targets* a um *Endpoint* (*AuthEndpoint*, *APIEndpoint*, *StaticAsset*), por *exhibitsBehavior* a um perfil comportamental, e por *mitigatedBy* a uma política (*RateLimit*, *Challenge*, *Block*) que carrega um atributo *scope*. A classe abstrata *ApplicationLayerAttack* especializa-se em *SlowHTTPDoSFamily*, por sua vez dividida em *ConnectionExhaustionAttack* (*Slowloris*, corpo lento, leitura lenta) e *CoordinatedHTTPFlood* (*HULK*, *GoldenEye*). A ontologia está alinhada a STIX 2.1 [20] e MITRE ATT&CK, e declara também *CredentialStuffing* e *CoordinatedAPIAbuse*, que reaproveitam a mesma maquinaria mas ficam fora do escopo experimental deste artigo.

C. Modelo de Ameaça

O defensor opera a aplicação atacada e observa, por requisição, o *ClientHello* TLS (logo, uma impressão digital JA4), endereço e prefixo/ASN de origem, *endpoint* alvo, instante de chegada e todo o material de identidade que a aplicação expõe. Ele não vê o canal de controle da *botnet* nem quais origens são coordenadas, mas pode perfilar o tráfego do próprio serviço fora de episódios de ataque. O atacante controla *K* dispositivos comprometidos e pode moldar cada sessão para ser estatisticamente indistinguível de uma legítima, que é a premissa de

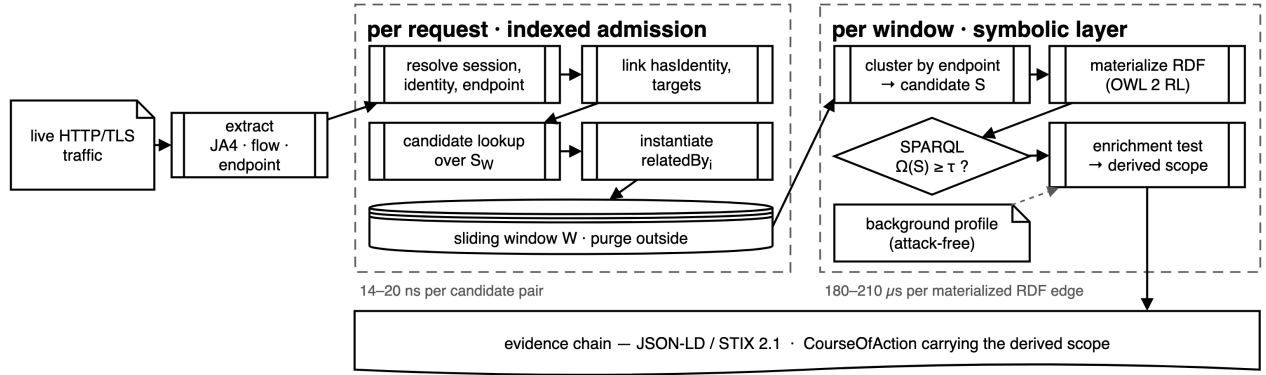


Fig. 2. Pipeline de execução, por requisição e por janela.

furtividade da nossa avaliação. Temporização, identidades e cargas úteis podem receber ruído, ser rotacionadas ou aleatorizadas, cada uma a um custo operacional que a ponderação da Seção III-D codifica. A pilha TLS é mais difícil de trocar, porque é fixada pela biblioteca que cada dispositivo embarca, como nas *botnets* de roteadores, câmeras e DVRs da linhagem Mirai [21]. Apresentar o *ClientHello* de um navegador exigiria levar uma biblioteca de personificação a cada dispositivo e mantê-la em dia com as versões dos navegadores. Bots que fazem isso, como fazendas de navegadores *headless*, ficam fora deste modelo, e as Seções V-D e VI os avaliam como sua fronteira.

D. A Família *relatedTo* Ponderada

A relação entre sessões é uma família estruturada de relações, declarada via `rdfs:subPropertyOf` sob uma *relatedTo* transitiva e anotada com um `coordinationWeight` $w_i \in [0, 1]$, representada na Fig. 1. Cada uma é instanciada de forma independente a partir de sua própria evidência observada, de modo que duas sessões podem ficar ligadas por uma, por várias ou por todas as seis.

A ordenação é um argumento de custo de evasão para esse atacante. Trocar a pilha TLS significa substituir a biblioteca em cada dispositivo, e o JA4 ordena as extensões antes de calcular o *hash*, de modo que permanece estável sob a aleatorização de extensões que o Chrome introduziu em 2023, a qual quebra o JA3 clássico [19]. Reaproveitar identidade é igualmente caro de quebrar, porque espalhar uma campanha por muitas credenciais mina sua economia. A coerência temporal tem origem no modo como a *botnet* é operada, e ruído aleatório pode quebrá-la em parte. Os sinais de carga útil e de *endpoint* são intermediários: aleatorizá-los é barato, mas fazê-lo custa coerência à campanha. A proximidade de rede é o elo mais fraco por construção: derivados do Mirai, frotas em nuvem e redes de *proxy* residencial se espalham por ASNs e prefixos, e o NAT de operadora torna um /24 compartilhado um discriminador pobre. A calibração do Apêndice B corrobora a ordenação, e não faz afirmação alguma sobre os valores absolutos.

E. Construção do Grafo em Tempo de Execução

Sessões e relações vivem dentro de uma janela operacional deslizante ($W = 5$ min por padrão) e são expurgadas incrementalmente, seguindo uma disciplina de processamento de fluxo RDF, com materialização sobre Apache Jena Fuseki e armazenamento TDB2. A Fig. 2 dispõe as duas camadas e as taxas em que operam, e o Apêndice A traz o algoritmo de construção e o procedimento por par de cada sub-relação *relatedBy*. Casamentos exatos de JA4, de *endpoint* e de prefixo são relações de equivalência, de modo que cada um particiona S em classes e $|E_i(S)| = \sum_k \binom{n_k}{2}$ sobre seus tamanhos. Admitir uma sessão passa então a incrementar um contador de classe por sub-relação desse tipo, a um custo que não depende de $|S_W|$, e $\Omega(S)$ dispensa arestas de par. Apenas as relações não transitivas (JA4 por variante próxima, temporal, carga útil) comparam pares candidatos, que índices de prefixo e *hashing* sensível à localidade restringem. A Seção V-E mede os dois caminhos contra a ocupação da janela.

F. Regra de Detecção

Seja V_{sess} o conjunto de sessões ativas em W . Para um subconjunto $S \subseteq V_{\text{sess}}$ e um *endpoint* candidato e , define-se a massa de coordenação

$$\Omega(S) = \sum_{i \in \mathcal{R}_{\text{rel}}} w_i |E_i(S)|, \quad (1)$$

com $E_i(S) = \{\{s_a, s_b\} \subseteq S : (s_a, \text{relatedBy}_i, s_b) \in E\}$ o conjunto de pares de sessões ligados pela sub-relação i . As sub-relações são simétricas, então cada par conta uma vez. A regra *CoordinatedHTTPFlood* vale quando existe S com (i) $|S| \geq k_{\text{min}}$; (ii) $\forall s \in S : (s, \text{targets}, e) \in E$; (iii) $\Omega(S) \geq \tau_{\text{cluster}}$; (iv) taxa agregada em e acima de τ_{rate} ; e (v) um perfil *BotBehavior* coerente.

A condição (iii) é a contribuição. $\Omega(S)$ pode ultrapassar o limiar com *relatedByNetworkProximity* em zero, o caso da *botnet* distribuída, desde que alguma combinação de sinais de peso alto esteja presente. Em sentido contrário, um conjunto sustentado apenas por proximidade de rede, como usuários móveis atrás de um mesmo /24 de CGN, precisa de três vezes

mais pares ligados para alcançar o mesmo Ω que um conjunto ligado por TLS. Como τ_{cluster} é calibrado sobre agrupamentos benignos, a agregação comum de CGN fica abaixo dele, o que protege contra um modo de falso positivo bem conhecido.

G. Formulação Simbólica

O raciocínio é simbólico em dois estágios deliberados. Regras SWRL instanciam a família `relatedBy` par a par sobre predicados que os extratores de evidência produzem: as relações baseadas em igualdade são Horn puras, enquanto as numéricas, como distância DTW e similaridade de cosseno de carga útil, são avaliadas de antemão e entram na regra como comparação embutida contra seu limiar. A agregação não é Horn, porque o SWRL não soma, de modo que $\Omega(S)$ é computado por uma consulta SPARQL que lê os pesos das anotações `coordinationWeight` da ontologia e, para as relações baseadas em igualdade, conta os pares pelo tamanho das classes. A Listagem 1 mostra uma regra de cada tipo.

H. Cadeia de Evidência e Escopo de Mitigação Derivado

Quando a regra dispara, o motor emite a regra satisfeita, as instâncias envolvidas, a decomposição de $\Omega(S)$ por sub-relação e o escopo de mitigação derivado. Exportamos isso como JSON-LD e como STIX 2.1, um *indicator* mais um *course-of-action* ligados por *mitigates*, para ingestão por SIEM e SOAR.

Como o escopo é escolhido decide se o veredicto é útil ou prejudicial, e a escolha por frequência falha. A impressão digital modal do agrupamento seleciona aquilo que é comum, e em um serviço sob ataque o que é comum é a população legítima. Contra uma *botnet* espalhada por várias pilhas TLS, cada pilha do atacante é menor que a cabeça da distribuição benigna, de modo que o valor modal é uma impressão digital *legítima* e o filtro resultante bloqueia usuários e nenhum atacante (Seção V-D).

Selecioneamos, portanto, o discriminador por **enriquecimento**. Seja $c(f)$ a prevalência da impressão digital f dentro do agrupamento que disparou e $b(f)$ sua prevalência em um perfil de fundo de tráfego normal mantido pelo operador fora dos episódios de ataque. O escopo admite todo f com $c(f)/b(f) \geq \rho$ e $c(f) \geq \sigma$, produzindo um *conjunto* de impressões digitais, que é o que cobre uma *botnet* fragmentada. O piso de suporte σ precisa ficar abaixo da fatia da menor pilha sobre a qual valha a pena agir, isto é, abaixo de $1/M$ para uma *botnet* de M pilhas. Baixá-lo não custa nada, porque é o teste de enriquecimento que mantém o tráfego legítimo de fora. Usamos $\rho = 3$ e $\sigma = 0,002$.

O fundo precisa vir de fora do episódio de ataque, porque a campanha se estende por toda a janela e, de outro modo, daria a todo candidato enriquecimento igual a um. Nenhum rótulo está envolvido: o perfil é o que um defensor vê em operação normal. Um adversário que se esconda dentro de uma impressão digital benigna popular não está, portanto, enriquecido, de modo que o *framework* recusa o escopo e reporta que não existe discriminador.

IV. METODOLOGIA DE AVALIAÇÃO

Esta seção detalha a metodologia de avaliação. Descrevemos primeiro os cenários e as fontes de tráfego por trás deles, tanto o gerador sintético calibrado quanto as capturas públicas, junto com os parâmetros que decidem o quanto um cenário se aproxima de produção. Em seguida apresentamos as linhas de base, as configurações de ablação que isolam a contribuição da representação, e as métricas em que todo resultado é reportado.

A. Cenários e Conjuntos de Dados

A hipótese central tem duas partes: a representação entre sessões ganha da detecção por sessão à medida que o *grau de distribuição* K da campanha cresce, e o caminho simbólico converte essa estrutura em uma decisão auditável e de baixo colateral. A avaliação é, portanto, parametrizada por K . O **Cenário A** ($K = 1$) é a inundação clássica de origem única, que detectores volumétricos já tratam e que é degenerada para a área sob a curva ROC (AUC) por sessão. O **Cenário B** ($10 \leq K \leq 100$) modela *botnets* pequenas cujas origens permanecem, cada uma, dentro do próprio limite de taxa, de modo que a proximidade de rede é parcial e os sinais de peso alto precisam sustentar a detecção. O **Cenário C** ($K \geq 1000$) espalha a campanha por centenas de ASNs e prefixos, deixando sinal por sessão desprezível e uma `relatedByNetworkProximity` quase vazia. É aqui que a contribuição precisa se sustentar. Reportamos B ($K = 50$) e C ($K = 1000$).

Avaliação primária: tráfego sintético calibrado. Um gerador produz campanhas distribuídas de Slow HTTP DoS, a família da Seção III-B: sessões sustentadas de baixa taxa contra um único *endpoint*, com verdade de referência de coordenação conhecida, parametrizadas por K , pela fração de origens que compartilham assinatura TLS e identidade, pela dispersão de IP/ASN e pela janela de tempo.

Dois parâmetros desse gerador decidem se o cenário se parece com produção: a popularidade de impressões digitais benignas, que medimos, e a composição da *botnet*, que nenhuma medição publicada fixa e por isso varremos. O primeiro é modelado como uma curva de Zipf de expoente α : populações reais são concentradas, já que um navegador atualizado em uma dada plataforma emite essencialmente um único JA4 [19]. Calibramos essa curva contra 6,33M de requisições TLS registradas em um ponto de presença de borda em produção da Azion Technologies¹: 495 impressões digitais distintas, a mais comum respondendo por 38,4% das requisições e as dez primeiras por 93,8%. A curva medida é delimitada por $\alpha = 1,5$ e $\alpha = 2,0$. Tomamos $\alpha = 1,5$ como canônico e varremos a faixa. Quanto à composição da *botnet*, *botnets* reais abrangem classes de dispositivo como roteadores, câmeras IP e DVRs [21], e portanto pilhas TLS, de modo que distribuímos a campanha uniformemente por M pilhas, a escolha conservadora para um dado M , e tomamos $M = 25$

¹Medido em 22 de agosto de 2026 a partir de um *log* de acesso que a plataforma já coleta. O extrato guarda apenas impressões digitais de software cliente e suas frequências, sem endereço, *host*, URI, cabeçalho ou localidade.

como canônico. Um modo *adversarial* permite que a *botnet* adote as impressões digitais benignas mais comuns, como faria um bot que personifica navegador, e marca a fronteira do modelo de ameaça. O Apêndice B relata a medição e suas ressalvas.

As distribuições legítimas são calibradas contra as ~ 322 mil sessões benignas do CICIDS2017 e verificadas por testes de Kolmogorov–Smirnov: $D = 0,003$ para duração e $D = 0,002$ para contagem de requisições, ambos com $p > 0,8$, de modo que o ganho não pode vir de tráfego benigno artificialmente fácil. Um modo *furtivo* sorteia as sessões do atacante das mesmas distribuições do tráfego benigno, de modo que a campanha só se revela pela estrutura entre sessões.

Dados reais. CICIDS2017 [22] (captura de quarta-feira: Slowloris, Slowhttptest, HULK, GoldenEye) e CIC-IoT2023 [23], este último o conjunto sobre o qual o KLAGE reporta $F_1 = 84,1\%$ para DDoS Slowloris, passam pelo mesmo *pipeline* de extração (PCAP $\rightarrow$ JA4 + fluxos $\rightarrow$ sessões $\rightarrow$ grafo). Ambos são capturas de bancada de laboratório, ressalva à qual retornamos na Seção VI.

B. Linhas de Base, Configurações e Métricas

Cada configuração da ablação é executada com $n = 30$ sementes distintas, produzindo intervalos por *bootstrap* e testes pareados. Todas as configurações consomem os mesmos atributos de tráfego, de modo que a ablação separa *representação*, não disponibilidade de dados. τ_{cluster} é fixado por cenário no percentil 99 de Ω sobre agrupamentos legítimos.

A linha de base por sessão é deliberadamente **forte**: uma Random Forest (RF) sobre todos os oito a nove atributos de fluxo disponíveis (contagem e duração de requisições, somas de bytes e pacotes em ambos os sentidos, média e desvio padrão do intervalo entre requisições). Para que o resultado negativo não dependa de uma única classe de hipóteses, repetimo-lo com *gradient boosting* por histograma, um *perceptron* multicamadas e regressão logística sobre os mesmos atributos. Reimplementamos também três linhas de base acadêmicas: perfilamento por PCA [10], PCA seguido de agrupamento por k -médias sobre uma matriz comportamental [9] e RF/SVM supervisionados sobre atributos de sessão [5]. Comparamos contra os números publicados do KLAGE no mesmo conjunto e ataque. As quatro configurações de ablação são: **(a)** linha de base de aprendizado de máquina sem ontologia; **(b)** ontologia *sem* sub-relação *relatedBy*, com sessões como nós isolados; **(c)** ontologia *apenas* com *relatedByNetworkProximity*, emulando um detector ingênuo de ASN/prefixo; e **(d)** a representação completa entre sessões sobre as três sub-relações observáveis no tráfego avaliado. Assim (d)–(a) é a contribuição total, (d)–(b) o ganho de representar estrutura entre sessões, e (d)–(c) o ganho dos sinais de peso alto sobre a proximidade de rede.

A configuração (d) consome a evidência entre sessões como *atributos*: a fração do agrupamento que compartilha um mesmo JA4 ou /24, mais seu tamanho. Esse substituto em nível de atributo para a família *relatedBy* mantém todas as configurações iguais em dados e classificador.

Tabela II
ROC AUC POR SESSÃO, CENÁRIO SINTÉTICO REALISTA.

Configuração	$K = 50$	$K = 1000$
(a) ML por sessão (forte)	0,498 [47–53]	0,503 [50–51]
(b) ontologia, sem <i>relatedBy</i>	0,500 [47–53]	0,502 [49–51]
(c) só <i>NetworkProximity</i>	0,499 [46–53]	0,659 [65–67]
(d) repr. entre sessões	0,927 [92–93]	0,982 [98–98]
<i>(a) e (d) por família de classificador (estimativas pontuais)</i>		
<i>gradient boosting</i>	0,502 / 0,921	0,501 / 0,990
<i>perceptron</i> multicamadas	0,471 / 0,235 [†]	0,500 / 0,803
regressão logística	0,488 / 0,873	0,495 / 0,799
PCA sobre estatística de fluxo [10]	0,518	0,509
PCA e k -médias sobre matriz de sessão [9]	0,499	0,495
Supervisionado sobre atributos de sessão [5]	0,499	0,503

$\alpha = 1,5$, $M = 25$, $n = 30$ sementes, IC 95%, usuários legítimos no serviço atacado. A configuração (d) alcança a evidência entre sessões por atributos, então a tabela mede a representação. O caminho simbólico está na Tabela III. [†] abaixo do acaso: o *perceptron* inverte, tendo aprendido que uma impressão digital amplamente compartilhada significa tráfego benigno.

Além das métricas usuais de classificação, reportamos **dano colateral**: a fração de tráfego legítimo que cai dentro do escopo derivado do veredicto. Trata-se da taxa de falsos positivos do filtro que um operador implantaria, que pode diferir muito da do detector (Seção V-D). As cadeias de evidência são avaliadas quanto a *completude* (enumeram toda sessão correlacionada e toda sub-relação ativada?) e *acionabilidade* (o escopo derivado é coerente com o discriminador do agrupamento?).

V. RESULTADOS

Os resultados seguem as afirmações que sustentam. Começamos pela ablação que isola a representação sob campanhas furtivas distribuídas, depois medimos a regra simbólica diretamente como detector, sem classificador treinado sobre seus atributos, e confrontamos ambos com tráfego real e com o sistema publicado mais próximo. As subseções restantes quantificam quanto o veredicto custa uma vez que se age sobre ele: o dano colateral do escopo derivado, o custo de execução de cada camada e a escolha de W , e a significância estatística das comparações.

A. Ablação em Campanhas Furtivas Distribuídas

A Tabela II reporta a AUC por sessão em campanhas furtivas distribuídas nas quais usuários legítimos acessam o *mesmo endpoint* na mesma porta do ataque, de modo que nem volume de fluxo nem porta de destino separam as duas classes. O padrão sobrevive a uma linha de base forte: a detecção por sessão (a) com o conjunto completo de atributos de fluxo, as três linhas de base acadêmicas e a configuração (b), que acrescenta atributos ontológicos por sessão mas nenhuma relação entre sessões, todas ficam no acaso ($AUC \approx 0,50$), porque cada sessão do atacante é, por construção, sorteada das distribuições benignas. A representação entre sessões (d) alcança 0,93–0,98. A configuração (c), restrita à proximidade de rede, é fraca (0,50–0,66) porque a *botnet* está dispersa.

Entre as quatro classes de hipóteses, a configuração (a) permanece no acaso em todas as famílias, entre 0,471 e 0,503,

Tabela III
O CAMINHO SPARQL/ENRIQUECIMENTO COMO DETECTOR.

Cenário	Regra Simbólica			Modelo Aprendido (d)		
	Revoc.	TFP	F_1	AUC	Revoc. @	TFP= 0
Monolítica ($M=1$)	84,0%	0,00%	0,885	0,997	91,7%	
$M=5$	90,0%	0,00%	0,948	0,996	88,6%	
$M=25$	90,3%	0,00%	0,949	0,979	36,4%	
$M=100$	85,0%	0,00%	0,919	0,961	17,6%	
$M=25$, adversarial	30,4%	3,78%	0,452	0,862	7,8%	

O modelo aprendido é forçado ao ponto de operação da própria regra, exceto na linha adversarial. $K = 1000$, $n = 15$ sementes. TFP: taxa de falsos positivos.

o que localiza o colapso na representação: nenhuma classe de hipóteses recupera o que os atributos descartaram.

É na configuração (d) que a escolha do modelo começa a importar, e o cenário realista expõe por quê. Fragmentar a *botnet* em 25 pilhas torna a evidência entre sessões *não monotônica* no rótulo: um atacante compartilha impressão digital com algumas dezenas de pares, enquanto um cliente legítimo na cabeça da distribuição benigna a compartilha com centenas. Ensembles de árvores recortam a faixa intermediária e alcançam 0,98–0,99 em $K = 1000$ e 0,92–0,93 em $K = 50$. A regressão logística, restrita a uma resposta monótona, cai para 0,80 e 0,87, e o *perceptron* inverte por completo em $K = 50$ (AUC = 0,235), tendo aprendido que uma impressão digital amplamente compartilhada indica tráfego benigno.

A não monotonicidade é um argumento a favor do caminho simbólico. Um modelo aprendido precisa inferir a linha de base benigna de sua amostra de treino e codificá-la em uma fronteira, enquanto a regra da Seção III-H compara contra um perfil explícito. O enriquecimento, por isso, se comporta de modo uniforme ao longo da faixa de fragmentação em que os aprendizes divergem.

Que (b) também fique no acaso mostra que atributos por sessão não bastam: é a *relação explícita entre* sessões que sustenta a detecção. A massa de $\Omega(S)$ que dispara a regra é dominada por *relatedByTLSFingerprint* ($w = 1,0$) e pela convergência de *endpoint*, enquanto *relatedByNetworkProximity* não ativa em campanhas dispersas. Avaliamos também a qualidade da cadeia de evidência sobre sete agrupamentos reais de ataque: todas listam a regra satisfeita, as sub-relações ativadas e seus pesos, o escore $\Omega(S)$ e o escopo derivado, e produzem um filtro utilizável (Listagem 2, Apêndice D). Um estudo com analistas humanos é trabalho futuro.

B. A Própria Regra como Detector

Todo número até aqui veio de um classificador sobre atributos entre sessões, o que nada diz sobre a camada simbólica. Avaliamos, portanto, a regra diretamente: as sessões que casam com o escopo derivado na Seção III-H *são* o conjunto sinalizado, sem treino de modelo e sem limiar de escore aprendido, e a decisão chega acompanhada de sua derivação. Como a AUC é uma medida de ordenação e a regra emite uma decisão dura, forçamos também o classificador ao ponto de operação da própria regra (Tabela III).

Contra uma *botnet* monolítica ou pouco fragmentada, o modelo aprendido é competitivo em zero falsos positivos (91,7% e 88,6% de revocação contra 84,0% e 90,0%): não há vantagem simbólica no regime fácil. A partir de 25 pilhas a regra abre vantagem clara: 90,3% contra 36,4%, e 85,0% contra 17,6% em cem pilhas, e a regra mantém essa dianteira mesmo contra um modelo autorizado a gastar falsos positivos: em 1% de TFP o modelo alcança apenas 66,8% e 44,5%. A linha adversarial *não* é uma comparação equivalente e dela não extraímos afirmação alguma: ali a própria regra incorre em uma taxa de falsos positivos de 3,78%, e o modelo alcança 23,4% uma vez autorizado a 1%, de modo que a ordem em um ponto de operação equiparado fica indefinida.

A AUC sozinha não captura esse comportamento no ponto de operação. O classificador ainda pontua 0,979 e 0,961 onde recupera um terço e um sexto do ataque: sua ordenação é boa, mas seus escores se sobrepõem ao tráfego benigno na cauda, de modo que nenhum limiar rende ação automática sem colateral. A regra não produz escore para limiarizar, apenas um conjunto definido por um teste de enriquecimento contra um fundo explícito, de modo que sua taxa nula de falsos positivos nesses cenários decorre desse critério, sem limiar ajustado por trás. Isso não é uma garantia incondicional.

C. Tráfego Real e Comparação com o KLAGÉ

Em tráfego real, o quadro por sessão muda (Tabela IV). Uma linha de base *enxuta* por sessão (três atributos) desaba para $F_1 = 0,179$, mas uma *forte* (oito atributos de fluxo) alcança 0,900, porque o Slowloris real do CIC-IoT2023, ao contrário das nossas campanhas furtivas, deixa assinatura de fluxo por sessão. O *framework* entre sessões alcança 0,911, à frente por apenas +0,011, de modo que nesse ataque a coordenação entre sessões não é necessária. A comparação com o KLAGÉ é favorável, mas *não controlada*: nosso 0,911 supera o 0,841 publicado, e nossa linha de base forte também, de modo que a margem não pode ser creditada à representação entre sessões. Uma reexecução controlada não é possível, já que o código liberado parte de um grafo pré-construído cuja construção não foi publicada, e não distribui pesos. Os conjuntos públicos de DDoS contêm apenas ataques com assinatura de fluxo evidente, e não têm o regime furtivo distribuído em que a evidência entre sessões se torna necessária (Fig. 4, Apêndice C). Em qualquer regime, a abordagem acrescenta ao estado da arte em nível de nó um veredicto simbólico auditável e uma medida de dano colateral.

Tabela IV
DDoS SLOWLORIS NO CIC-IoT2023 (*dados reais*).

Método	F_1	Prec.	Revoc.	AUC
KLAGÉ, nível de nó [7]	0,841	-	-	-
(a) ML por sessão, 3 atrib.	0,179	0,691	0,103	0,551
(a') ML por sessão, 8 atrib.	0,900	0,901	0,899	0,987
(d) entre sessões (nosso)	0,911	0,908	0,915	0,982

A captura abrange 143 prefixos /24 distintos.

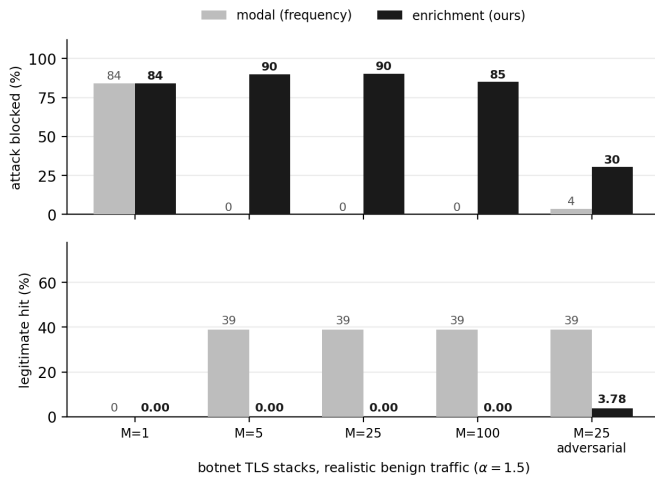


Fig. 3. Derivação do escopo: frequência contra enriquecimento ($\alpha = 1,5$, $n = 15$).

D. Dano Colateral em Tráfego Legítimo

A mitigação só faz sentido como par: o que o escopo derivado bloqueia e quanto isso custa. Reportamos ambos sobre $n = 15$ campanhas por configuração, comparando a regra por frequência com a regra por enriquecimento da Seção III-H (Fig. 3).

Para uma *botnet* monolítica as duas concordam: 84,0% das sessões do atacante bloqueadas sem colateral observado, contra 100% de um limite global de taxa no *endpoint*, que por definição desconecta todo usuário legítimo do serviço atacado. Esse é o regime em que a regra por frequência foi validada, e ele não é representativo. A partir de cinco pilhas, a impressão digital modal do agrupamento passa a ser uma *legítima* e a regra se inverte: 0,0% do ataque bloqueado e 39,0% do tráfego legítimo atingido, uma perda líquida que impõe o custo da mitigação sem o benefício dela. Uma população benigna mais concentrada ($\alpha = 2,0$) eleva esse colateral a 61,1%.

O enriquecimento elimina a falha, bloqueando 90,0%, 90,3% e 85,0% do ataque em $M = 5, 25$ e 100 pilhas, em todos os casos **sem colateral observado** nas $n = 15$ campanhas, e reproduzindo a regra por frequência onde ela funcionava. Os 10 a 15% que sobrevivem são a cauda de atacantes com impressões digitais únicas: a mitigação com escopo troca completude por precisão.

Dois condições limitam o resultado. A primeira é a fronteira do modelo de ameaça: quando a *botnet* adota impressões digitais benignas comuns, pouco fica enriquecido e a regra bloqueia 30,4% do ataque a 3,78% de colateral, contra 3,6% e 39,0% da regra por frequência. A vantagem de seletividade se perde em grande parte, mas se perde de forma *segura*: com um ρ mais estrito o escopo se recusa a nomear uma impressão digital e degenera para o controle global, que é o relato correto quando não existe discriminador. A segunda é o perfil de fundo. Deriva moderada é tolerável (perfil com $\alpha = 2,0$ contra episódio com $\alpha = 1,5$: 90,3% de cobertura, 0,45% de colateral). Um perfil achatado ou ausente não é, já que toda impressão digital passa a parecer rara, a cabeça benigna

pontua como enriquecida e o colateral salta para 81,2%. A qualidade do perfil governa a precisão e deixa a cobertura inalterada, de modo que manter o perfil atualizado é requisito de implantação. Disso decorre também um mecanismo à prova de falhas: onde o perfil reprovar em uma verificação de frescor ou de deriva, a mitigação com escopo é suprimida e o veredicto emitido apenas como evidência, como o teste de enriquecimento faz quando nada está enriquecido.

E. Custo e a Escolha de W

O Apêndice D mede os dois caminhos contra a ocupação da janela. Mantidas como classes, as sub-relações baseadas em igualdade tornam a admissão constante em cerca de $0,37 \mu s$ por sessão e a camada simbólica linear, com 26,4 s para 100 000 sessões, contra 52,8 s com arestas de par em 1 000. $\Omega(S)$ continua crescendo com o quadrado do agrupamento, já que conta pares. Calculá-lo deixou de crescer assim. A detecção é plana ao longo de uma faixa de $30\times$ em W (Tabela V), de modo que W pode ser tão pequeno quanto o tráfego permitir.

F. Significância Estatística

Testes de Wilcoxon pareados sobre as $n = 30$ execuções, com correção de Bonferroni e d de Cohen, tornam ambos os contrastes significativos no regime distribuído ($K = 1000$) em $p_{\text{Bonf}} = 7,5 \times 10^{-9}$: (d)–(c) com $d = 13,5$ e (d)–(a) com $d = 22,4$. A correlação bisserial de postos por pares casados é +1,00 em ambos, com (d) vencendo as 30 execuções pareadas. As sementes são sorteios de um mesmo gerador, então os testes mostram que a diferença é estável entre sorteios desse processo, e efeitos dessa magnitude refletem a separação quase perfeita de tráfego sintético controlado. Nenhum dos dois deve ser lido como expectativa de desempenho em campo.

VI. DISCUSSÃO E LIMITAÇÕES

Primeiro situamos o *framework* em operação e discutimos como ele se particiona, depois enunciamos as cinco limitações que delimitam nossas afirmações. O Apêndice C lista outras.

Posicionamento operacional. O *framework* fecha um ciclo de gestão: detecção, evidência e escopo saem de uma única passagem sobre o mesmo grafo, de modo que o que chega ao operador ou a um *playbook* de SOAR é um *course-of-action* STIX já parametrizado pelo discriminador que justificou o veredicto.

Paralelismo e particionamento. A regra dita a chave natural de particionamento. A condição (ii) exige que toda sessão de S mire um mesmo *endpoint*, de modo que particionar a janela por *endpoint* avalia a regra de forma *exata*, sem tráfego entre partições e com estado por partição limitado pela janela. O preço é que uma campanha que espalha um mesmo JA4 por muitos *endpoints* acumula pares de menos em cada partição para ultrapassar τ_{cluster} , enquanto particionar por JA4 quebra a condição de *endpoint*. Nenhuma chave isolada preserva as seis sub-relações, e o Apêndice D esboça um desenho em dois níveis.

O ganho é específico de regime. Contra inundações de origem única, limiares por IP ou por sessão têm desempenho comparável, e nos ataques reais convencionais de conjuntos públicos um classificador forte por sessão já alcança $AUC \geq 0,98$. A vantagem só se sustenta quando a campanha é distribuída e furtiva, e o *framework* complementa as defesas volumétricas.

A avaliação sintética demonstra um mecanismo e não estabelece desempenho em campo. No cenário sintético, a campanha carrega exatamente os sinais de coordenação que a configuração (d) mede, e as sessões do atacante tiram seus atributos por sessão de distribuições benignas reais. A não separabilidade por sessão da Tabela II não é, portanto, artefato de uma linha de base enfraquecida. A imitação, porém, é imposta por construção, de modo que o resultado mostra o mecanismo sob indistinguibilidade perfeita por sessão e não estabelece desempenho sobre uma captura real desse regime.

Deteção e definição de escopo dependem ambas de um discriminador observável de peso alto. Uma varredura de robustez ($n = 10$) torna a dependência explícita: à medida que a fração de origens que compartilham a impressão digital TLS cai, a $AUC(d)$ decresce monotonicamente de 1,00 para $\approx 0,74$ sob aleatorização, resíduo deixado pelo conjunto finito de JA4 benignos, que a diversidade em escala de internet deveria levar ao acaso. A convergência de *endpoint* não compensa, porque usuários legítimos também convergem no *endpoint*. A família ponderada tolera quebra parcial, já que os sinais de peso alto sobreviventes sustentam o agrupamento, mas um bot fora do modelo de ameaça que apresente o JA4 de um navegador enquanto introduz ruído temporal e rotaciona identidades a degrada em direção ao acaso. O Encrypted Client Hello [24] também pode tornar o JA4 inobservável.

Escopo da ablação. A configuração (d) exprime a evidência do grafo como atributos: um modelo linear sobre os mesmos três atributos entre sessões ainda alcança 0,799 contra 0,495 do conjunto por sessão, de modo que o ganho de AUC da Tabela II vem de representar estrutura entre sessões, e o OWL não acrescenta nada a esse número. O que o OWL acrescenta é operacional. O veredicto, sua decomposição por sub-relação e o escopo formam uma única derivação, exportada para STIX sem tradução (Listagem 2), e um sinal novo entra como uma sub-propriedade ponderada que a agregação lê da ontologia. Chamamos o veredicto de *explicável* nesse sentido de derivação inspecionável. Se ele encurta a decisão de um analista permanece não testado. A Tabela III sustenta o caminho simbólico apenas em parte: ele fica atrás do modelo aprendido contra uma *botnet* monolítica e toma a frente quando a fragmentação torna a distribuição de escores inutilizável para um limiar de zero falsos positivos.

Cobertura de família de ataque, protocolo e conjunto de dados. A ontologia e a avaliação cobrem a família Slow HTTP DoS sobre HTTP/1.1, e HTTP/2 ou outros protocolos exigem sub-relações adicionais. A validação em dados reais abrange seis ataques de laboratório em dois conjuntos, e a comparação de ataque único com o KLAGÉ difere em granularidade e protocolo, de modo que uma afirmação de superioridade exige

reproduzir o KLAGÉ sob nosso protocolo.

VII. CONCLUSÃO E TRABALHOS FUTUROS

Modelamos a sessão HTTP como entidade de primeira classe, relacionada a outras sessões por seis sub-propriedades tipadas ponderadas pelo custo de evasão, e dispparamos uma regra SPARQL/SWRL cuja derivação serve de veredicto, cadeia de evidência e escopo de mitigação.

Contra campanhas furtivas de *botnets* de dispositivos comprometidos, a detecção por sessão fica no acaso em quatro famílias de classificador, enquanto a representação entre sessões alcança ROC AUC 0,98, e em ataques reais convencionais basta um classificador forte por sessão. Definir o escopo pela propriedade que a maior parte do agrupamento compartilha seleciona uma impressão digital legítima assim que a *botnet* se espalha por várias pilhas TLS, e o enriquecimento sobre um perfil de tráfego normal restaura de 85 a 90% de cobertura sem colateral observado. Como detector, o caminho simbólico recupera 90% de uma campanha de 25 pilhas onde o modelo aprendido recupera 36% com zero falsos positivos, diferença que a AUC esconde. As direções imediatas são ataques sobre HTTP/2, uma avaliação semi-sintética sobre tráfego de fundo de produção e uma campanha furtiva capturada, que nenhum *benchmark* ainda fornece.

AGRADECIMENTO

Agradecemos à Azion Technologies (<https://www.azion.com/>) por autorizar a medição de impressões digitais da Seção IV.

REFERÊNCIAS

- [1] MITRE Corporation, “CVE-2023-44487: HTTP/2 rapid reset attack,” National Vulnerability Database, 2023. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2023-44487>
- [2] Google Cloud, “How it works: The novel HTTP/2 ‘Rapid Reset’ DDoS attack,” Google Cloud Blog, 2023. [Online]. Available: <https://cloud.google.com/blog/products/identity-security/how-it-works-the-novel-http2-rapid-reset-ddos-attack>
- [3] Cloudflare, “Hyper-volumetric DDoS attacks skyrocket: Cloudflare’s 2025 Q2 DDoS threat report,” Cloudflare Blog, 2025. [Online]. Available: <https://blog.cloudflare.com/ddos-threat-report-for-2025-q2/>
- [4] E. Cambiaso, G. Papaleo, G. Chiola, and M. Aiello, “Slow DoS attacks: Definition and categorisation,” *International Journal of Trust Management in Computing and Communications*, vol. 1, no. 3–4, pp. 300–319, 2013.
- [5] C. Kemp, C. Calvert, T. M. Khoshgoftaar, and J. L. Leevy, “An approach to application-layer DoS detection,” *Journal of Big Data*, vol. 10, no. 1, p. 22, 2023.
- [6] M. Odusami, S. Misra, O. Abayomi-Alli, A. Abayomi-Alli, and L. Fernández-Sanz, “A survey and meta-analysis of application-layer distributed denial-of-service attack,” *International Journal of Communication Systems*, vol. 33, no. 18, p. e4603, 2020.
- [7] L. Belcastro, C. Carlucci, C. Cosentino, P. Liò, and F. Marozzo, “Enhancing network security using knowledge graphs and large language models for explainable threat detection,” *Future Generation Computer Systems*, vol. 176, p. 108160, 2026.
- [8] J. Zhang, H. Zhang, C. Xia, and L. Sun, “Graph-BERT: Only attention is needed for learning graph representations,” *arXiv preprint arXiv:2001.05140*, 2020.
- [9] R. Bharathi and R. Sukanesh, “A PCA based framework for detection of application layer DDoS attacks,” *WSEAS Transactions on Information Science and Applications*, vol. 9, no. 12, pp. 389–398, 2012.

- [10] G. Fernandes Jr., J. J. P. C. Rodrigues, and M. L. Proença Jr., “Autonomous profile-based anomaly detection system using principal component analysis and flow analysis,” *Applied Soft Computing*, vol. 34, pp. 513–525, 2015.
- [11] L. Sadlek, M. Husák, and P. Čeleda, “Identification of device dependencies using link prediction,” in *Proc. IEEE/IFIP Network Operations and Management Symp. (NOMS)*, 2024, pp. 1–10.
- [12] X. Wang and R. Stadler, “IT intrusion detection using statistical learning and testbed measurements,” in *Proc. IEEE/IFIP Network Operations and Management Symp. (NOMS)*, 2024, pp. 1–7.
- [13] A. Martinetti, “Advancing threat intelligence: JA4 fingerprints and inter-request signals,” Cloudflare Blog, Aug. 2024. [Online]. Available: <https://blog.cloudflare.com/ja4-signals/>
- [14] Y. Jia, Y. Qi, H. Shang, R. Jiang, and A. Li, “A practical approach to constructing a knowledge graph for cybersecurity,” *Engineering*, vol. 4, no. 1, pp. 53–60, 2018.
- [15] V. Bonagiri, P. Priyadarshini, P. PanneerSelvi, S. Sahitya, R. Swamy, and P. Varalakshmi, “Practical applications of cybersecurity: A research paper on knowledge graphs for real-world security solutions,” in *Proc. 4th Asian Conf. on Innovation in Technology (ASIANCON)*, 2024.
- [16] K. Liu, F. Wang, Z. Ding, S. Liang, Z. Yu, and Y. Zhou, “Recent progress of using knowledge graph for cybersecurity,” *Electronics*, vol. 11, no. 15, p. 2287, 2022.
- [17] N. Tripathi and N. Hubballi, “Application layer denial-of-service attacks and defense mechanisms: A survey,” *ACM Computing Surveys*, vol. 54, no. 4, pp. 1–33, 2021.
- [18] W3C OWL Working Group, “OWL 2 web ontology language profiles, 2nd ed.” W3C Recommendation, 2012. [Online]. Available: <https://www.w3.org/TR/owl2-profiles/>
- [19] J. Althouse, J. Smart, R. J. Nunnally, and M. Brady, “JA4+ network fingerprinting,” FoxIO, 2023. [Online]. Available: <https://blog.foxio.io/ja4+-network-fingerprinting>
- [20] OASIS, “STIX version 2.1,” OASIS Standard, 2021. [Online]. Available: <https://docs.oasis-open.org/cti/stix/v2.1/stix-v2.1.html>
- [21] M. Antonakakis, T. April, M. Bailey, M. Bernhard, E. Bursztein, J. Cochran, Z. Durumeric, J. A. Halderman, L. Invernizzi, M. Kallitsis, D. Kumar, C. Lever, Z. Ma, J. Mason, D. Menscher, C. Seaman, N. Sullivan, K. Thomas, and Y. Zhou, “Understanding the Mirai botnet,” in *Proc. 26th USENIX Security Symposium*, 2017, pp. 1093–1110.
- [22] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward generating a new intrusion detection dataset and intrusion traffic characterization,” in *Proc. 4th Int. Conf. on Information Systems Security and Privacy (ICISSP)*, 2018, pp. 108–116.
- [23] E. C. P. Neto, S. Dadkhah, R. Ferreira, A. Zohourian, R. Lu, and A. A. Ghorbani, “CICIoT2023: A real-time dataset and benchmark for large-scale attacks in IoT environment,” *Sensors*, vol. 23, no. 13, p. 5941, 2023.
- [24] E. Rescorla, K. Oku, N. Sullivan, and C. A. Wood, “TLS encrypted client hello,” IETF Internet-Draft draft-ietf-tls-esni, 2024. [Online]. Available: <https://datatracker.ietf.org/doc/draft-ietf-tls-esni/>
- [25] M. Shafi, A. H. Lashkari, V. Rodriguez, and R. Nevo, “Toward generating a new cloud-based distributed denial of service (DDoS) dataset and cloud intrusion traffic characterization,” *Information*, vol. 15, no. 4, p. 195, 2024.

APÊNDICE A

CONSTRUÇÃO EM TEMPO DE EXECUÇÃO E INSTANCIÇÃO DAS SUB-RELAÇÕES

Algoritmo 1 Construção do grafo de conhecimento em tempo de execução

Requer: fluxo de requisições $\mathcal{R}$, ontologia $\mathcal{O}$, janela W
Garante: grafo de conhecimento KG persistente ao longo de W

```

1:  $KG \leftarrow \emptyset$ 
2: for cada requisição  $r \in \mathcal{R}$  do
3:    $s, i, e \leftarrow \text{RESOLVESSÃO/IDENTIDADE/ENDPOINT}(r)$ 

4:    $KG.add(s, i, e); KG.link(s, hasIdentity, i)$ 
5:    $KG.link(s, targets, e)$ 
6:   for cada  $s' \in S_W$  ativa,  $s' \neq s$  do
7:     for cada sub-relação  $i \in \mathcal{R}_{rel}$  do
8:       if  $\text{VALE}_i(s, s')$  then
9:          $KG.link(s, relatedBy_i, s')$ 
10:      end if
11:    end for
12:  end for
13:   $KG.purgeOutside(W)$ 
14: end for
15: return  $KG$ 

```

O Algoritmo 1 constrói o grafo sobre a janela deslizante. Para cada par (s_a, s_b) ativo em W , os procedimentos a seguir decidem se a aresta é instanciada.

TLSFingerprint. Casamento em dois estágios: igualdade exata do JA4 completo ou, na falta dela, variantes próximas (mesmo prefixo de transporte/versão TLS/ALPN, com no máximo um símbolo de diferença nos blocos ordenados de cifras ou extensões), instanciadas com anotação $ja4_distance = 1$. Isso absorve a deriva de versão dentro de uma mesma biblioteca cliente sem admitir casamentos espúrios entre pilhas distintas. Custo $O(1)$ por par.

ReusedIdentity. Instanciada em qualquer interseção não vazia entre os conjuntos de identidade observados, $(\text{cookie}(s_a) \cap \text{cookie}(s_b)) \cup (\text{token}(s_a) \cap \text{token}(s_b)) \cup (\text{user}(s_a) \cap \text{user}(s_b)) \neq \emptyset$. JWTs são decodificados e comparados pela *claim* sub; *cookies* e nomes de usuário são normalizados (corte de espaços, caixa baixa). Custo $O(1)$ amortizado com índice invertido.

TemporalPattern. Com $\Delta(s)$ a sequência de intervalos entre chegadas, computamos $d_{DTW}(s_a, s_b) = DTW(\Delta(s_a), \Delta(s_b)) / \max(|\Delta(s_a)|, |\Delta(s_b)|)$ e instanciamos quando $d_{DTW} \leq \tau_{DTW}$. Sessões com menos de três requisições são ignoradas. O FastDTW sob uma banda de Sakoe-Chiba de largura constante reduz o custo por par de $O(n^2)$ para $O(n)$, e o *hashing* sensível à localidade sobre vetores-resumo ($\delta, \sigma_\delta, \delta_{\min}, \delta_{\max}$, entropia) evita a comparação de todos os pares.

PayloadSignature. Com $\mathbf{p}(s) = (\overline{\text{len}}, \sigma_{\text{len}}, h_{UA}, h_{CT})$, isto é, média e desvio padrão do tamanho de corpo mais *hashes* do User-Agent e do Content-Type dominantes, a aresta é

```

# SWRL (Horn): instancia uma sub-relacao
ApplicationSession(?a) ^ ApplicationSession(?b) ^
differentFrom(?a,?b) ^
tlsJa4(?a,?j) ^ tlsJa4(?b,?j)
-> relatedByTLSFingerprint(?a,?b)

# SPARQL: agregacao ponderada pelo tamanho das classes
SELECT ?e (SUM(?w * ?n * (?n - 1) / 2) AS ?omega)
WHERE {
  { SELECT ?e ?c (COUNT(?s) AS ?n)
    WHERE { ?s kg:targets ?e ; kg:inClass ?c . }
    GROUP BY ?e ?c }
  ?c kg:ofRelation ?rel .
  ?rel rdfs:subPropertyOf kg:relatedTo ;
    kg:coordinationWeight ?w . }
GROUP BY ?e
HAVING (SUM(?w * ?n * (?n - 1) / 2) >= ?tau)

```

Listagem 1. Veredicto como derivação: uma regra de Horn e a agregação SPARQL.

instanciada quando a similaridade de cosseno excede τ_{payload} . Custo $O(1)$ dados os vetores pré-computados.

EndpointConvergence. Instanciada quando ambas as sessões convergem no mesmo *endpoint*, sob normalização de padrão de caminho (/api/users/12345 → /api/users/{id}) por padrão; um casamento adicional de caminho exato anota a aresta com *exact* = *true*. Custo $O(1)$ com índice em árvore de prefixos.

NetworkProximity. Instanciada em prefixo IPv4 /24 (ou IPv6 /48) compartilhado, ou em ASN compartilhado, ou em ambos; quando ambos valem, a aresta é anotada com *strong* = *true*. A resolução de ASN usa tabelas BGP correntes. Custo $O(1)$ com índice invertido de prefixos.

APÊNDICE B CALIBRAÇÃO DOS PESOS

A calibração empírica depende criticamente do realismo do tráfego. Em conjuntos de laboratório, com algumas dezenas de impressões digitais JA4 distintas, a otimização chega a inverter o sinal do indicador TLS, porque sessões benignas compartilham impressões digitais mais do que campanhas parcialmente coordenadas; isso é artefato de bancada, oriundo da baixa diversidade de JA4 e ausente da internet real.

No cenário realista (milhares de JA4 legítimos, usuários acessando o serviço atacado), calibramos maximizando a ROC AUC por sessão entre ataque e benigno sobre o escore $w_{\text{tls}} z(\text{ja4}) + w_{\text{ep}} z(\text{conv. endpoint}) + w_{\text{net}} z(\text{prox. rede})$ com atributos padronizados, sobre a grade $\{0,3 \dots 1,0\}^3$ (125 combinações, 60 cenários, 91 500 sessões). O resultado corrobora a ordenação proposta: o melhor vetor é $(w_{\text{tls}}=1,0, w_{\text{ep}}=0,3, w_{\text{net}}=0,3)$, e a impressão digital TLS é o único sinal individualmente discriminativo (AUC isolada = 0,93, contra 0,50 da convergência de *endpoint* e 0,58 da proximidade de rede). Os pesos da Fig. 1 (1,0, 0,6, 0,3) atingem a mesma AUC = 0,943 ótima e são insensíveis a perturbação de $\pm 20\%$. A calibração valida, portanto, a *ordenação*; no regime puro de mesmo serviço os pesos médio e baixo não são separadamente identificáveis, já que ambos ficam próximos do acaso, e seus valores absolutos permanecem em aberto à espera de tráfego de produção com sinais parciais e conflitantes.

Realismo do Gerador

Duas ressalvas se aplicam à medição em produção da popularidade de impressões digitais benignas. O *log* não carrega identificador de conexão, então a ponderação é por requisição e não por sessão, o que dá peso excessivo a clientes pesados e, se enviesada, *superestima* a concentração; e a amostra é de um ponto de presença em uma janela. A bancada do CICIDS2017 [22] é ainda mais concentrada (cabeça de 52,7%), de modo que o formato de laboratório é apenas indicativo. A curva medida também não é exatamente Zipf: sua cabeça casa com $\alpha = 1,5$ (38,9% contra 38,4%), enquanto suas dez primeiras casam com $\alpha = 2,0$ (94,2% contra 93,8%), de modo que a varredura a delimita.

APÊNDICE C LIMITAÇÕES ADICIONAIS

Instrumentação de sessão e identidade. A abordagem pressupõe que sessões, identidades e impressões digitais TLS possam ser extraídas dos eventos de tráfego; onde essa instrumentação for parcial ou ruidosa, o desempenho cai.

Custo de manutenção do grafo. Os números simbólicos do Apêndice D são um limite superior, pela razão ali exposta, e escalar para tráfego de CDN exige o particionamento da Seção VI, que não implementamos.

Cobertura de protocolo. A ontologia atual cobre a família Slow HTTP DoS sobre HTTP/1.1. Ataques sobre HTTP/2 e outros protocolos de aplicação (DNS, gRPC) exigem sub-relações adicionais.

Cobertura de sub-relações. O $\Omega(S)$ avaliado instancia três das seis sub-relações, a saber impressão digital TLS, convergência de *endpoint* e proximidade de rede, que são as que o gerador e as capturas públicas expõem. Reaproveitamento de identidade, padrão temporal e assinatura de carga útil estão especificados no Apêndice A mas não são exercitados, de modo que os pesos da Fig. 1 valem apenas para aquelas três.

Amplitude de conjuntos de dados. A validação em dados reais cobre um conjunto e um ataque na comparação direta, mais seis ataques entre CICIDS2017 e CIC-IoT2023 na análise de regime. RT-IoT2022, CIC-DDoS2019 e tráfego de produção anonimizado permanecem trabalho futuro. A lacuna persiste em *benchmarks* mais novos: o BCCC-cPacket-Cloud-DDoS-2024 [25] aponta a representação inadequada de ataques de camada de aplicação como deficiência de conjunto de dados, mas seus 17 cenários de DDoS são todos baseados em TCP. Entre os *benchmarks* examinados não encontramos captura independente do regime furtivo de camada 7 estudado aqui.

Validação da explicação. As cadeias de evidência passam nas verificações automáticas de completude e acionabilidade da Seção IV (7/7). Não realizamos estudo com usuários, então se elas encurtam o tempo de decisão de um analista permanece não testado.

APÊNDICE D MODELO DE CUSTO E SENSIBILIDADE À JANELA

A admissão acontece por requisição, enquanto a materialização e a agregação de Ω rodam uma vez por janela, então

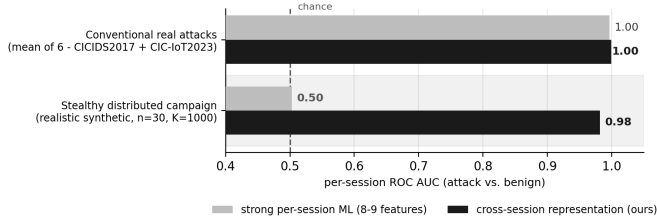


Fig. 4. Onde a evidência entre sessões é necessária.

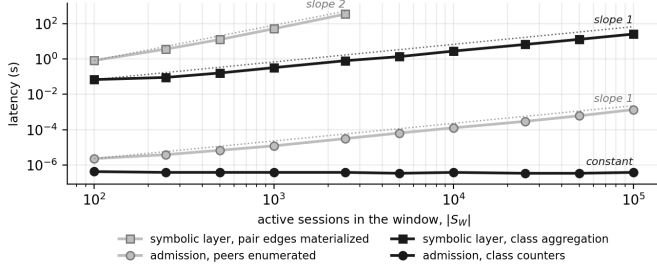


Fig. 5. Custo das duas camadas, com arestas de par e com contagens de classe.

cronometramos as duas camadas separadamente, sobre uma janela sintética na mistura realista (30% das sessões em uma campanha compartilhando um JA4 de *botnet*, JA4 benignos de um conjunto de 2000, oito *endpoints*, /24s dispersos), com medianas de três repetições em um núcleo. Cada camada roda de dois modos: com arestas de par, como as regras estão escritas, e com contagens de classe para as sub-relações baseadas em igualdade. Os dois dão o mesmo $\Omega(S)$ para todo *endpoint*, com diferença de até 7×10^{-12} . Este é um modelo de custo do algoritmo, não um *benchmark* de sistema: a camada simbólica roda sobre *rdfLib* em memória, não sobre o *backend* Jena/TDB2, de modo que seus números são um limite superior.

Com enumeração de pares, a latência mediana de admissão cresce de 2,3 μ s em $|S_W| = 100$ para 127 μ s em $|S_W| = 10000$, acompanhando a contagem de pares candidatos (de 148 a 6495 arestas por admissão) a 15–21 ns por par. Com contadores de classe, ela fica entre 0,33 e 0,42 μ s de 100 a 100 000 sessões (Fig. 5, onde as linhas pontilhadas são inclinações de referência).

Materializar arestas de par custa 0,84 s em $|S_W| = 100$ e 52,8 s em 1000, entre 198 e 309 μ s por aresta RDF, de modo que esse caminho é linear em arestas e quadrático em sessões. A agregação por classes materializa uma tripla de pertinência por sessão e sub-relação e calcula $\Omega(S)$ com a consulta da Listagem 1 em 0,33 s para 1000 sessões, 161 vezes mais rápido, e em 26,4 s para 100 000. O termo quadrático vive, assim, no valor de $\Omega(S)$, que conta pares, e nas arestas de par das sub-relações não transitivas, cujos candidatos os índices restringem. A cadeia de evidência precisa apenas das contagens de pares (Listagem 2), que as classes fornecem diretamente.

W entra apenas pela atribuição de agrupamentos de detec-

Tabela V
VARREDURA DE JANELA, $K = 1000$, $n = 10$ SEMENTES.

W (s)	agrup.	$ S $ médio	(a)	(b)	(c)	(d)
60	16	132	0,505	0,508	0,664	0,976
120	11	207	0,505	0,508	0,663	0,977
300	6	364	0,505	0,508	0,664	0,977
600	4	557	0,505	0,508	0,664	0,978
1800	3	867	0,505	0,508	0,664	0,978

```
"@type": "kg:CoordinatedHTTPFlood",
"kg:clusterSize": 6, "kg:coordinationScore": 10.8,
"kg:activatedSubRelations": [
{"@type": "kg:relatedByEndpointConvergence",
"kg:coordinationWeight": 0.6, "kg:linkedPairs": 15,
"kg:weightedContribution": 9.0},
{"@type": "kg:relatedByNetworkProximity",
"kg:coordinationWeight": 0.3, "kg:linkedPairs": 6,
"kg:weightedContribution": 1.8}],
"kg:derivedMitigationScope": {
"kg:endpoint": "192.168.10.50:80",
"kg:srcNet24": "172.16.0.0/24"}
```

Listagem 2. Cadeia de evidência do agrupamento DoS-Other do CICIDS2017, resumida.

ção, de modo que a varredura recomputa os atributos entre sessões sobre os mesmos cenários em cache. A Tabela V mostra que a detecção é insensível a ele entre 60 e 1800 s: o atributo discriminativo é a *fração* de um agrupamento que compartilha um mesmo JA4, que não muda conforme o agrupamento cresce, enquanto o tamanho sozinho carrega pouco; daí (c) em 0,664 em toda a faixa. Dois limites: os cenários miram um único *endpoint*, de modo que W é o único botão de agrupamento e uma implantação com muitos *endpoints* pode se comportar de outra forma; e W precisa ser longo o bastante para que um agrupamento se forme, o que em $W = 60$ s já significa ≈ 132 sessões.

Particionamento em Escala de CDN

O desenho que o particionamento por *endpoint* sugere, não implementado aqui, é de dois níveis: trabalhadores particionados por *endpoint* mais um esboço global sobre identificadores de peso alto para recuperar campanhas que se espalham por vários *endpoints*. Quantificar a revocação perdida pelo primeiro nível e recuperada pelo segundo é pré-condição para implantação em escala de CDN. Com o modelo de custo acima, o particionamento por *endpoint* é exato e dispensa coordenação, a contagem por classes mantém as duas camadas lineares na janela, e a admissão leva bem menos de um microssegundo. Confirmar isso em escala de CDN permanece trabalho futuro.

APÊNDICE E REPRODUTIBILIDADE

A implementação de referência está disponível em <https://github.com/NatanaelOliveira/knowledge-graph-ddos-article> sob licença permissiva. Ela é organizada por estágio experimental: o *pipeline* de extração (PCAP $\rightarrow$ JA4 e fluxos $\rightarrow$ sessões $\rightarrow$ grafo); o gerador calibrado, com os parâmetros de realismo da Seção IV e suas configurações canônica e

adversarial; a ablação, as linhas de base acadêmicas, as quatro famílias de classificador e o executor estatístico; a camada simbólica, com as regras SWRL mais a agregação SPARQL cujos pesos são lidos da ontologia; e os módulos de evidência e mitigação.

As duas derivações de escopo são distribuídas lado a lado: a regra por frequência que falha e a regra por enriquecimento que a substitui, de modo que o resultado negativo da Seção V-D seja reprodutível e não apenas afirmado. O perfil de fundo de que o teste de enriquecimento precisa é produzido por uma execução do gerador livre de ataque, de modo que nenhum rótulo entra no caminho de decisão em momento algum.

As sementes são fixas, a orquestração é conduzida por Makefiles e os artefatos são versionados, de modo que toda tabela e toda figura de dados se regeneram a partir de um único comando por estágio. A Fig. 1 é um esquema; sua fonte acompanha o artefato. A ontologia OWL é fornecida em RDF/XML, com toda sub-propriedade `relatedBy` anotada com seu `coordinationWeight`. Pretendemos submeter esses artefatos à trilha de Avaliação de Artefatos.